Introdução a Segurança de Dados

Segurança para proteger o quê?

Para **Proteger Valores**

- Exemplo: Instituição Financeira
  - Antigamente, os ativos eram físicos: papel moeda, ouro, etc
  - Em tempos atuais, os ativos são essencialmente digitais:

Dados, Informação

- Em computação, busca-se proteger dados, ou seja, criar mecanismos de segurança para um sistema computacional

Como Definir Segurança de Dados?

- A maneira como definimos Segurança de Dados norteia a construção de métodos para sua proteção

- Seguiremos uma definição que se tornou clássica, sob a qual serão discutidas as questões de segurança, tecnologias e ferramentas ao longo da disciplina

Segurança de Dados - Definição

- O National Institute of Standards and Technology (NIST) Computer Security Handbook define o termo Segurança de dados:

> Proteção a um sistema de informação automatizado, a fim de atingir os objetivos aplicáveis de preservar a integridade, disponibilidade e confidencialidade das fontes de informação do sistema (inclui hardware, software, firmware, informações/dados e telecomunicações).

Guttman e Roback. An Introduction to Computer Security: The NIST Handbook. Disponível em: https://www.nist.gov/publications/introduction-computer-security-nist-handbook

Proteger tudo?

Sim, mas antes é preciso classificar esse “tudo”

Exemplo: Ativos de instituições financeiras:

- Papel moeda (concreto): valor alto
- Sistema de Informações do Banco: valor variável (de baixo a muito alto)
  - Algumas informações são tratadas como sigilosas (alto valor)
  - Outras informações podem gerar pouca ou nenhuma consequência caso sejam roubadas (baixo valor)

Tipo de informação

Pública – informação que pode vir a público sem consequências danosas ao funcionamento normal da empresa;

Interna – o acesso a esse tipo de informação deve ser evitado, embora as consequências do uso não autorizado não sejam por demais sérias;

Confidencial – informação restrita aos limites da empresa, cuja divulgação ou perda pode levar a desequilíbrio operacional, e eventualmente, perdas financeiras;

Secreta – informação crítica para as atividades da empresa, cuja integridade deve ser preservada a qualquer custo e cujo acesso deve ser restrito a um número bastante reduzido de pessoas.

Os Fatores de Risco

Falta de consciência das ameaças e riscos do sistema de informação:

- As medidas de segurança muitas vezes não são consideradas até que uma empresa seja invadida por usuários mal-intencionados

Políticas de rede

- Muitos sites permitem acessos sem controle

Grande parte do tráfego da rede não é protegido (criptografado)

- O tráfego de rede pode ser monitorado, capturado ou adulterado

Ameaças, vulnerabilidades e controles

Vulnerabilidade

- Fraqueza no sistema de segurança que pode ser explorado para causar perda ou dano
- Exemplo: sistema sem autenticação para acesso aos dados

Ameaça

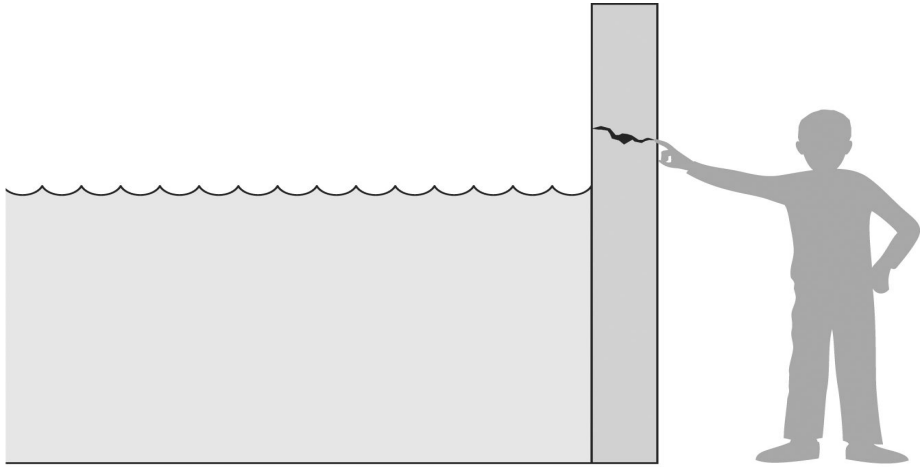
- Conjunto de circunstâncias que tem potencial para causar perda ou dano
- Risco: a possibilidade de ameaça de causar danos

Controle

- Uma medida de proteção
- Uma ação, procedimento, técnica que remove ou reduz uma vulnerabilidade

Ameaças, vulnerabilidades e controles

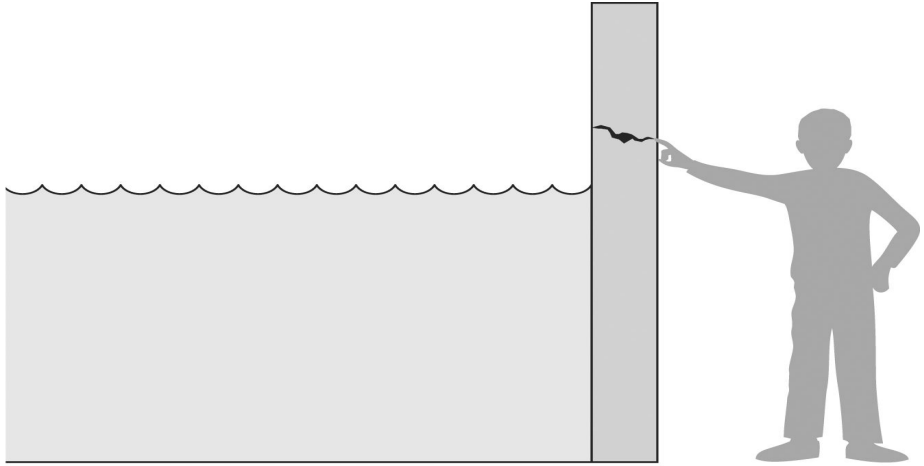
- Ex: uma barreira está segurando a água (ou rejeitos contaminados)
- **O que pode acontecer com o homem?**



Risco: possibilidade de morte, caso a **ameaça** de rompimento se concretizar

Ameaças, vulnerabilidades e controles

Ex: **ameaça** de rompimento pode existir, dadas as condições de projeto, de execução de obra ou de manutenção, que podem inserir **vulnerabilidades** ao sistema. Inspeções de rotina e contramedidas são **controles** de vulnerabilidades

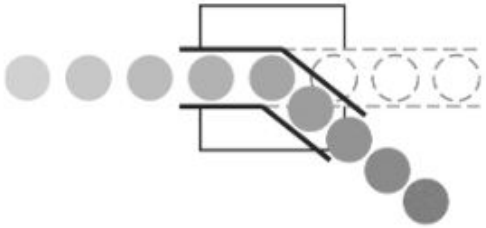


Uma ameaça é bloqueada pelo controle de vulnerabilidade

Ameaças à segurança

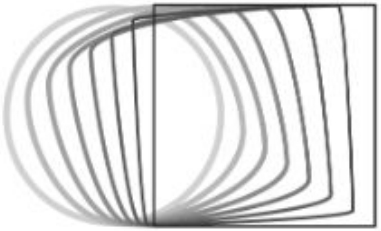
4 tipos de ameaça:

- Interceptação
- Interrupção
- Modificação
- Fabricação

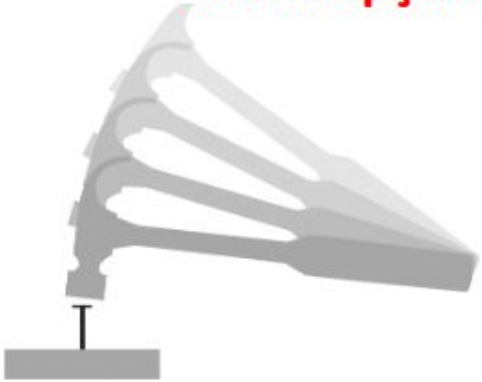


Interceptação

Interrupção



Modificação



Fabricação

Exemplos de Ameaças

Interceptação

- Acesso não autorizado: cópias ilegais de programas ou escutas

Interrupção

- Perda de um arquivo: destruição de hardware

Modificação

- Modificação não autorizada: mudança do Banco de dados

Fabricação

- Criação não autorizada: adição de um Registro no BD

Ataque à segurança

Ameaça inteligente, em ação

Ato inteligente que é uma tentativa deliberada de burlar os serviços de segurança e violar a política de segurança de um sistema

Método, Oportunidade, Motivo

Um atacante deve ter três coisas:

- Método: as competências, conhecimentos, ferramentas e outras coisas com o qual é capaz de obter sucesso no ataque
- Oportunidade: o tempo e acesso para realizar o ataque
- Motivo: uma razão para querer executar este ataque contra o sistema

(Pense na sigla "MOM")

Negar qualquer uma dessas três coisas pode permitir que o ataque não ocorrerá. No entanto, não é fácil controlar

Objetivos de Segurança (3 mais Básicos)

Confidencialidade (Secrecy)

– A informação somente pode ser acessada por pessoas explicitamente autorizadas

Integridade

– A informação deve ser restaurada em sua forma original

Disponibilidade

– A informação ou sistema de computador deve estar disponível no momento em que a mesma for necessária

Desafio: é necessário encontrar um certo equilíbrio entre esses objetivos, que frequentemente são conflitantes

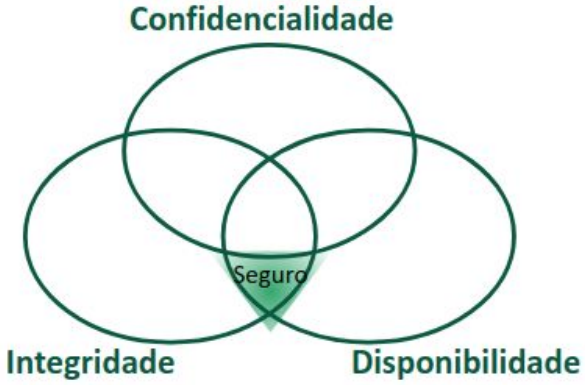
Relação entre os objetivos de segurança

Os 3 objetivos podem:

- ser independentes
- podem se sobrepor ou
- ser mutuamente exclusivos

Ex:

- Sistema financeiro com os 3 objetivos
- Portal web com 2 objetivos



Exemplo: Aplicação comercial

Confidencialidade - um funcionário de mais baixo escalão não deve saber o salário de seu diretor;

Integridade - um funcionário não deve ser capaz de modificar o próprio salário;

Disponibilidade - os pagamentos deverão ser emitidos a qualquer momento conforme estipulado por lei

Exemplo: Aplicação militar

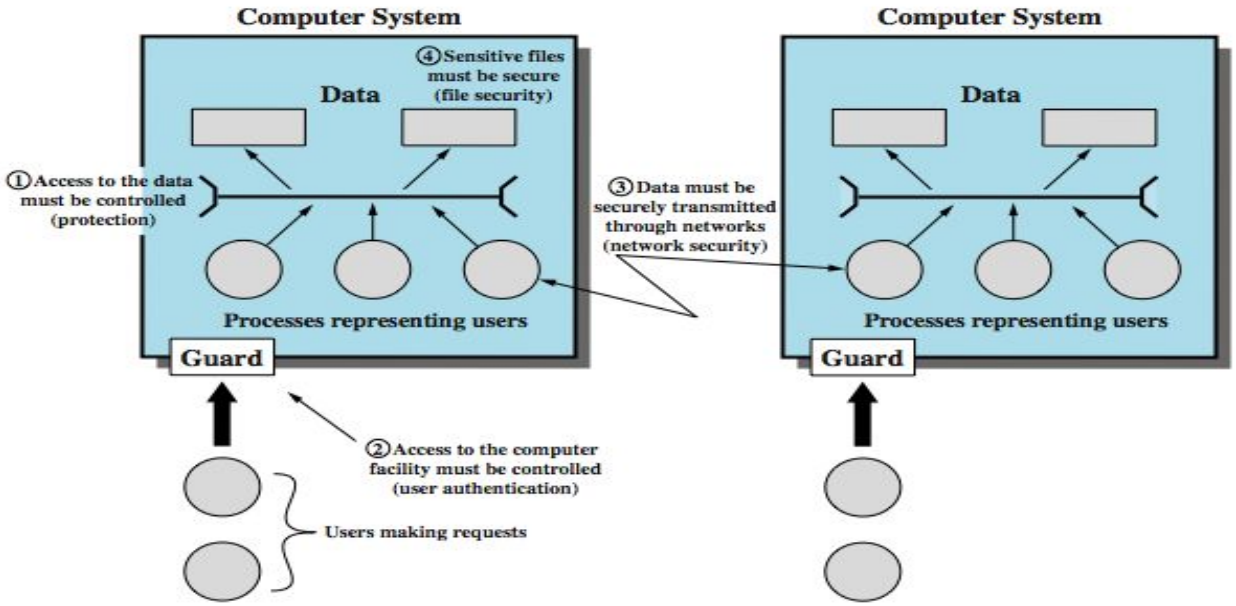
Confidencialidade - as coordenadas do alvo de um míssil não devem ser indevidamente divulgadas

Integridade - as coordenadas de um míssil não devem ser modificadas indevidamente

Disponibilidade - quando o comando apropriado é enviado, o míssil deve ser disparado

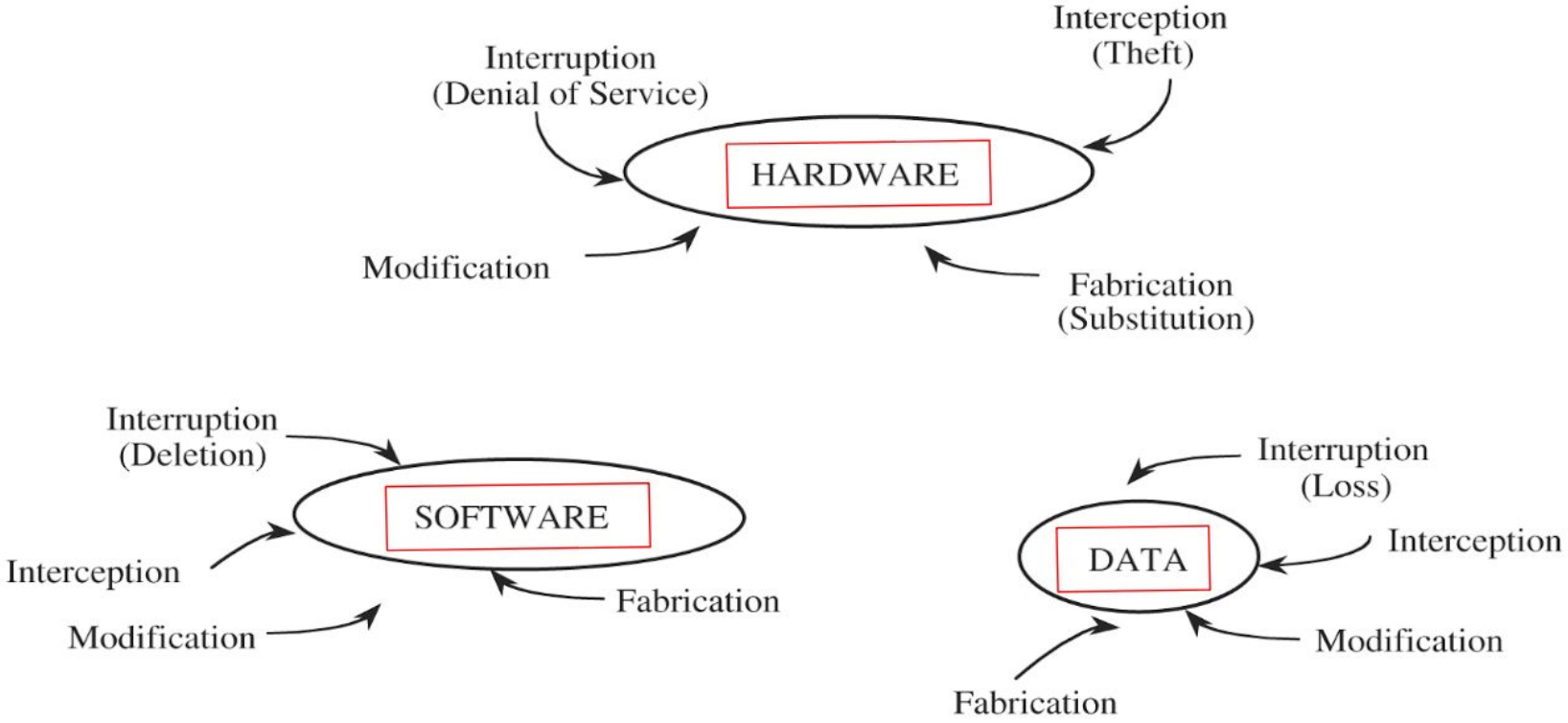
Segurança em Sistemas computacionais

Inclui variados níveis: nos processos, nos arquivos, nos vários dispositivos, na comunicação



Alvos de Ameaças

Dados, Software e Hardware são alvos nas 4 formas de ataque



Alvos de Ameaças

Exemplos para Software:

Confidencialidade – uma cópia não autorizada do software é realizada

Integridade – um programa é modificado para causar falha durante execução

Disponibilidade – programas são apagados, assim como acesso negado.

Pontos de Vulnerabilidade

Hardware – Dispositivos móveis são mais vulneráveis, porque eles são projetados para serem de fácil transporte

Software – Pode ser substituído, alterado, destruído, modificado, excluído ou extraviado acidentalmente. Se intencional ou não, esses **ataques exploram vulnerabilidades do software**.

Agentes de Crimes Computacionais

Amadores

- Pessoas normais que descobrem ter acesso a “algo” valioso
- Costuma ser principal fonte para crimes computacionais

Crackers

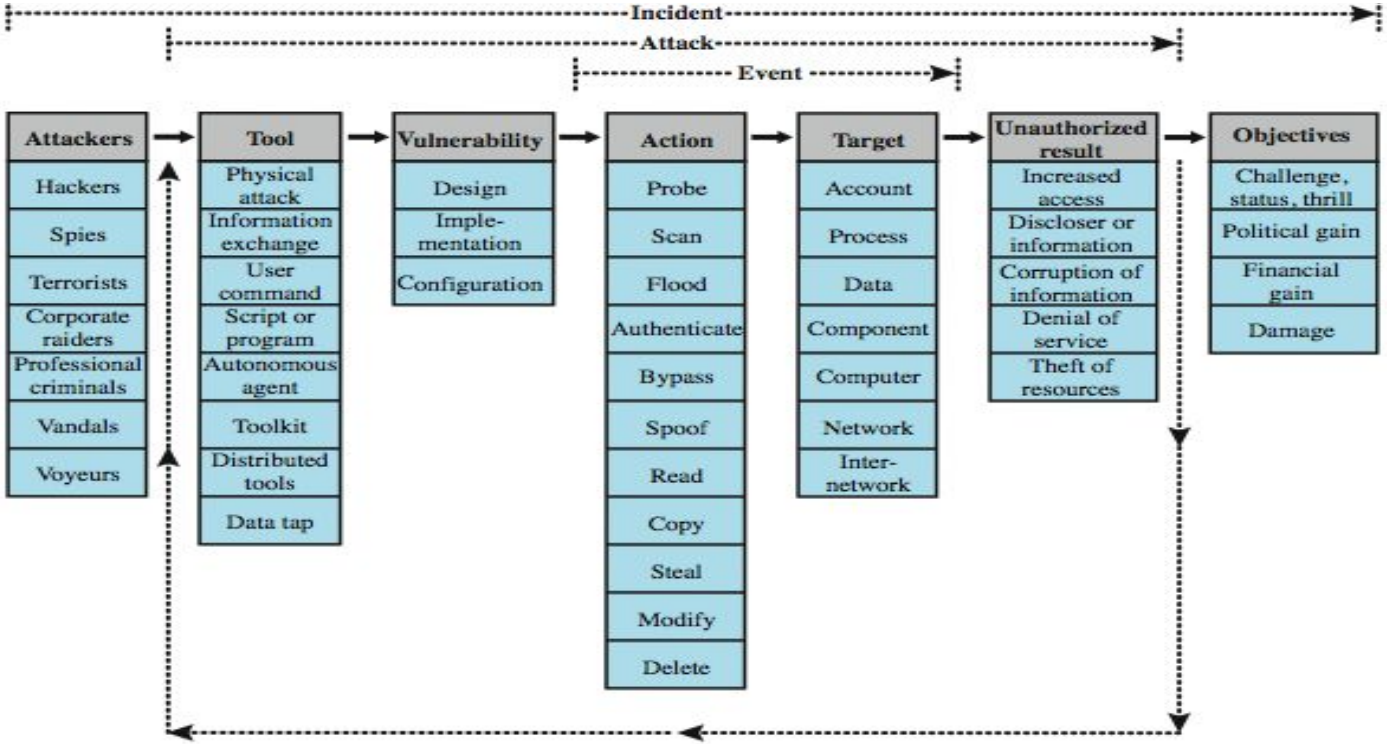
- Pessoas que “quebram” a segurança de um sistema com objetivos ilegais

Profissionais criminosos

- Profissionais de computação em quadrilhas envolvidas em crimes computacionais
- Spam, phishing, crimes de cartão de crédito, …
- Atualmente, uma das principais fontes de crimes eletrônicos

Incidentes de Segurança

Taxonomia de ataques e incidentes em rede e computadores



Estratégias de segurança

Política de segurança

- O que proteger?
- Quais controles?

Implementação e mecanismos de segurança

- Como?

Garantia de Segurança

- Funciona?
- Quanto?

Política de segurança

Envolvem todos os controles da organização, manuais e automatizados, que afetam as atividades dos Sistemas de Informação

Política de segurança

Fatores a serem considerados:

- O valor dos bens a serem protegidos
- As vulnerabilidades do sistema
- Ameaças potenciais e ataques possíveis

Balancear:

- Facilidade de uso X Nível de segurança
- Custo da segurança X Custo da falha e de recuperação

Política de segurança

Política de segurança:

- é decisão administrativa, de negócio
- pode ser influenciada por requisitos legais

Implementação e Mecanismos

Prevenção

- prevenir que um ataque seja bem sucedido

ex: controle de acesso ou cifras previnem ataque confidencialidade

Detecção

- Identificar, por ex., um acesso não autorizado

Resposta

- se um mecanismo detecta um ataque em andamento, deve reagir

Recuperação

- ex: dano de integridade deve ser corrigido (backup)

Mecanismo de segurança

Implementa funções que ajudam na

prevenção, detecção, resposta e recuperação

relacionados a possíveis ataques

Funções de segurança

são normalmente disponibilizadas para os usuários como um

conjunto de serviços de segurança através de

APIs ou interfaces integradas

Mecanismos: Formas de Controle

Criptografia - fundamental para quase todos os mecanismos

Hardware e Software de controle

- Exemplos: Controles de sistemas operacionais, firewalls

Políticas e procedimentos

- Exemplo: política de mudanças de senha

Controle físico

- Exemplos: guardas e portas trancadas

Mecanismos Específicos

- Cifragem
- Assinatura digital
- Controle de acesso
- Mecanismos de Integridade de dados
- Mecanismos de Autenticação
- Controle de roteamento
- Certificação

→ Serão estudados em aulas futuras

Serviços de Segurança (X.800)

Quando há **Comunicação**, os requisitos básicos são ampliados:

- Autenticação de entidade; de origem de dados
- Controle de Acesso: cada entidade deve ser identificada e autenticada
- Confidencialidade de Dados: proteção dos dados contra ataques passivos e análises
- Integridade de Dados: proteção dos dados em transmissão, contra modificação, fabricação, reordenação, repetição
- Irretratabilidade: impedir que uma entidade negue uma operação realizada (non-repudiation)
- Disponibilidade: um recurso ou serviço deve estar disponível

Eficiência dos controles

Consciência do problema

- Profissionais que usam mecanismos de controle devem estar convictos de sua necessidade para segurança

Probabilidade de uso

- Controles devem ser **eficientes**, **fáceis** de usar e apropriados para o problema (**custo** condizente)

Sobreposição de controles

- Combinação de controles para solucionar uma simples vulnerabilidade
  - Camadas de defesa
- Avaliação da eficiência do controle deve ser uma tarefa contínua
  - Revisões periódicas

Garantia da segurança

Com que eficiência o mecanismo de segurança garante a política determinada?

- Todos buscam ter alta garantia
- Mas alta garantia implica e elevação de custo
  - Talvez isso não seja possível
- Escolhas são necessárias
  - **Equilíbrio** é a palavra-chave

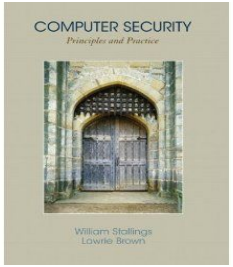
O Elo mais Fraco

- Segurança deve ser vista como uma **corrente** de proteção:
  - é um **conjunto de elos** que garante a proteção geral
  - é o elo mais fraco que tem mais chance de se partir

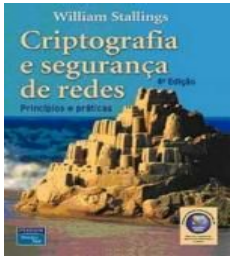
Estudo Individual

Leituras Sugeridas

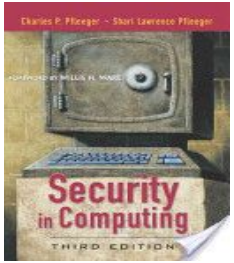
Stallings, W., Brown, L. Computer Security: Principles and Practice, ed. Prentice Hall, Capítulo 1.



Stallings, W. Criptografia e segurança de redes – Princípios e Práticas, 4 edição, ed Prentice Hall, Capítulo 1.



Charles P. Pfleeger and Shari L. Pfleeger. Security in Computing (3 nd edition). Prentice-Hall. 2003. ISBN: 0-13-035548-8.



Questões de Autoavaliação

(não precisa entregar)

Questões

1- Diferencie: vulnerabilidade, ameaça e controle.

2- Em relação aos ativos de um sistema computacional podemos categorizar hardware, software, dados, linha de comunicação e redes de computadores. Descreva os elementos em relação aos conceitos de integridade, confidencialidade e disponibilidade.

3- Roubo normalmente resulta em algum tipo de dano. Por exemplo, se alguém rouba o seu carro, você pode sofrer perdas financeiras, inconveniente (por perder o seu modo de transporte), e distúrbios emocionais (por causa da invasão de sua propriedade pessoal e espaço). Liste três tipos de danos que uma empresa pode ter por roubo de equipamento de informática.

4- Dê um exemplo de uma situação em que um compromisso de confidencialidade conduz a um compromisso de integridade.

5–Defina resumidamente as categorias de serviço de segurança de sistemas em rede.

6- Dê exemplos para os quatro tipos de ameaça para hardware e dado.